PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité des systèmes d'information

06-710 PSE 25-27 5-13 Sécurité des systèmes d'information - Menaces, protections et politique — source : fiche de révision du module (gemma4, 03/11/2026)

À RETENIR

1. Les menaces incluent l'accès non autorisé, les modifications, l'usurpation, l'impossibilité de prouver l'auteur ou la surcharge.
2. La cryptographie asymétrique utilise deux clés mathématiquement liées, une publique et une privée.
3. La PSSI est un document stratégique officiel qui formalise les objectifs et les règles de sécurité d'une organisation.

Menaces, causes et conséquences

Notion	À retenir
Cinq catégories menaces	Accès non autorisé (**confidentialité**), modifications (**intégrité**), usurpation (**authentification**), impossibilité de prouver l'auteur (**non-répudiation**) ou surcharge (**déni de service** / **DoS** / **DDoS**).
Causes fragilisation	Ouverture vers **Internet**, multiplication des points d'accès (**mobilité**, **télétravail**, **IoT**) et décentralisation (**cloud**, **edge computing**).
Conséquences attaques	Perte de réputation, sanctions (**RGPD**), avantage pour **États hostiles**, erreurs de diagnostics/transactions, pertes financières ou **paralysie complète** des opérations.

Mécanismes de protection par la cryptographie

Notion	À retenir
Principes et objectifs	Confidentialité (**symétrique/asymétrique**) , intégrité (**hachage** comme `SHA-256` ; `MD5` est **obsolète**), et authentification (**signatures numériques**).
Cryptographie symétrique	Une **seule clé** pour chiffrer/déchiffrer. Rapide et efficace. Limite : impossibilité d'identifier l'interlocuteur. **DES** (clé **56 bits**) est vulnérable.
Cryptographie asymétrique	Deux clés liées : **publique** (libre) et **privée** (secrète). **RSA** repose sur la **factorisation** de deux grands nombres premiers.
Gestion des clés (PKI)	Gère les certificats (**norme X.509**), les clés et les listes de révocation (**CRL**). Sécurise le **HTTPS** ou le **S/MIME**.

Dispositifs de protection des infrastructures et des flux

Notion	À retenir
Types de pare-feu	Filtrage de paquets (**OSI 3**, **ACL**), à mémoire (**OSI 4**, état des connexions, **NAT/PAT**), niveau circuit (deux connexions distinctes) ou niveau applicatif/**proxy** (**OSI 7**, analyse contenu HTTP/FTP).
Isolation DMZ	Zone tampon entre réseau interne et Internet. Ce que le support appelle « **trois interfaces** » = deux pare-feu en série (**back-to-back**) : la plus sûre. « **Une interface** » = un seul pare-feu (appelé couramment « à trois pattes ») : compromis, il ouvre le réseau interne.
Sécurisation VPN	Tunnel sécurisé par encapsulation. Protocoles : **PPTP** (déconseillé), **L2TP** (couplé à **IPsec**), **IPsec** (**OSI 3**, AH, ESP, IKE) ou **SSL/TLS** (**OSI 4**, via navigateur).

Organisation, PSSI et Analyse des risques

Notion	À retenir
Rôle de l'ANSSI	Créée en **2009**, rattachée au **Secrétaire général de la défense et de la sécurité nationale**. Définit les orientations, publie des guides et supervise la réponse aux cyberattaques.
La PSSI	Document stratégique officiel traduisant la vision de la direction. Décrit les enjeux, besoins (**confidentialité, intégrité, disponibilité**) et menaces. Opposable et sert de sensibilisation.
Méthodes d'analyse	**EBIOS Risk Manager** (publiée par l'ANSSI en **2018**) identifie menaces, vulnérabilités et impacts. **MEHARI** est une approche alternative axée sur l'évaluation et la priorisation.

Normes et gestion de la sécurité

Notion	À retenir
ISO 27002	Version **2013** (**14 domaines**) ; version **2022** : **93 mesures** en **4 thèmes** (**organisationnel**, **humain**, **physique**, **technologique**).
Actifs et RH	Gestion des actifs : **inventaire précis** et **classification**. RH : **sensibilisation** et **formation** adaptées, de l'**embauche** à la **vie professionnelle**.
Continuité et incidents	Incidents : **détection**, **réponse** et **récupération**. Continuité : **plans de reprise d'activité** pour maintenir les opérations et limiter l'impact sur les **services critiques**.

Pièges et confusions

- ⚠ Confondre l'intégrité (altération des données) avec la confidentialité (accès non autorisé).
- ⚠ Croire que la cryptographie symétrique permet d'identifier l'interlocuteur.
- ⚠ Oublier que le protocole L2TP nécessite d'être couplé à IPsec pour assurer la protection des données.
- ⚠ Confondre le filtrage de paquets basique avec le pare-feu à mémoire qui suit l'état des connexions.
- ⚠ Sous-estimer une DMZ à une interface qui est moins sécurisée qu'une architecture à trois interfaces.

Sigles et définitions

ANSSI Agence Nationale de la Sécurité des Systèmes d'Information créée en 2009

Confidentialité protection des informations sensibles contre l'accès d'acteurs non autorisés

Intégrité garantie que les données ne sont pas altérées de manière malveillante ou accidentelle

DoS attaque par déni de service visant à rendre un système inaccessible en le surchargeant de requêtes

PKI infrastructure de gestion des certificats numériques et des clés cryptographiques

DMZ zone tampon située entre le réseau interne et le réseau externe pour isoler les serveurs exposés

VPN réseau privé virtuel qui crée un tunnel sécurisé pour chiffrer les communications à distance

EBIOS méthode d'analyse des risques permettant d'identifier les menaces et les vulnérabilités

Auto-test

1. En quelle année l'ANSSI a-t-elle été créée ?
2. Quel protocole de niveau 3 sécurise les communications IP via AH, ESP et IKE ?
3. Quelle est la limite de la cryptographie symétrique ?
4. Quelle méthode d'analyse des risques a été publiée par l'ANSSI en 2018 ?
5. Combien de mesures compte la version 2022 de l'ISO 27002 ?

Réponses : **1.** 2009 · **2.** IPsec · **3.** impossibilité d'identifier l'interlocuteur · **4.** EBIOS Risk Manager · **5.** 93

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.